and afterwards a monotonically increasing sequence number is added to every message. If either side sees the sequence number go backwards then they abort the connection and a new handshake (and new challenge-response) needs to be performed. This relies on the fact that TLS is a stateful protocol between a single client and a single server, but this can't generally be guaranteed for an end-to-end security protocol where each API request may go to a different server.

Attacks from delaying, reordering, or blocking messages

Replay attacks are not the only way that an attacker may interfere with API requests and responses. They may also be able to block or delay messages from being received, which can in some cases cause security issues, beyond simple denial of service. For example, suppose a legitimate client sends an authenticated "unlock" request to a door lock device. If the request includes a unique nonce or other mechanism described in this section, then an attacker won't be able to replay the request later. However, they can prevent the original request being delivered immediately and then send it to the device later, when the legitimate user has given up and walked away. This is not a replay attack because the original request was never received by the API, instead the attacker has merely delayed the request and delivered it at a later time than was intended. https://datatracker.ietf.org/doc/html/draft-mattsson-core-coap-actuators-06 describes a variety of attacks against CoAP that don't directly violate the security properties of DTLS, TLS, or other secure communication protocols. These examples illustrate the importance of good threat modelling and carefully examining assumptions made in device communications. A variety of mitigations for CoAP are described in https://datatracker.ietf.org/doc/html/draft-ietf-core-echo-request-tag-09, including a simple challenge-response "Echo" option that can be used to prevent delay attacks, ensuring a stronger guarantee of freshness.

13.2.1 OSCORE

Object Security for Constrained RESTful Environments (OSCORE, https://tools.ietf.org/html/rfc8613) is designed to